



Корелација догађаја, ефективност контрола и учење

Корелација догађаја, процена контрола и постинцидентна анализа

Корелација и ефективност контрола

Догађаји добијају значење кроз заједнички контекст, а контрола се процењује на основу актуелног и проверљивог доказа.

ПРЕДМЕТ АНАЛИЗЕ

Ризик који се анализира

Процена безбедности обухвата везу између догађаја, контрола и доказа. Корелација даје контекст догађајима, а актуелан доказ омогућава процену рада контроле и последица инцидента.

ЗНАЧАЈ

Значај за безбедност система

Мерење ефективности спречава лажни осећај сигурности. Контрола која постоји, али је погрешно подешена, никада тестирана или без власника, не заслужује исто поверење као контрола са проверљивим доказом.

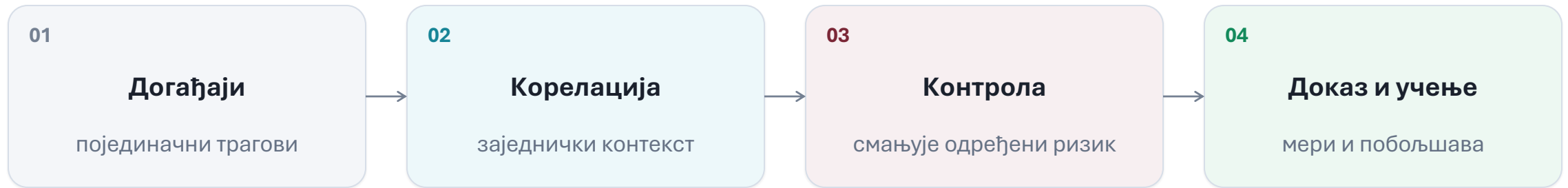
КРИТЕРИЈУМ ПРОВЕРЕ

Проверљив резултат

Одлука је јасна, примењује се на серверу и оставља поновљив доказ успешног и одбијеног исхода.

ОСНОВНИ ПОЈМОВИ

Догађаји, корелација, контрола и доказ омогућавају процену стварног безбедносног исхода.



ЗАКЉУЧАК

Безбедност напредује кроз повратну спрегу: доказ мења разумевање ризика, а то мења контролу.

Догађаји

појединачни трагови

01

Корелација повезује догађаје по времену, актеру и ресурсу, уз садржај појединачних порука лога.

Питање: који улаз покреће ову одлуку?

02

Корелација повезује низ догађаја у једну причу о понашању система.

Питање: која граница мора бити видљива?

03

Корелациони идентификатор повезује намеру, обраду и исход једне радње.

Питање: који доказ остаје после исхода?

ПИТАЊЕ ЗА АНАЛИЗУ

Који ризик контрола ублажава, који доказ чува и који сигнал показује да је престала да ради?

Корелација

заједнички контекст

01

Одговор са већим последицама захтева људску одлуку и јасан траг одобрења.

Питање: који улаз покреће ову одлуку?

02

Мера ефективности прати да ли контрола има власника, доказ и покривеност релевантног сценарија.

Питање: која граница мора бити видљива?

03

Правила корелације морају бити објашњива, посебно када утичу на приоритет упозорења.

Питање: који доказ остаје после исхода?

ПИТАЊЕ ЗА АНАЛИЗУ

Који ризик контрола ублажава, који доказ чува и који сигнал показује да је престала да ради?

Контрола

смањује одређени ризик

01

Постинцидентни преглед испитује системске и процесне узроке догађаја.

Питање: који улаз покреће ову одлуку?

02

Аутоматизован одговор може убрзати реакцију, али радња са великом последицом задржава људску потврду и ревизиони траг.

Питање: која граница мора бити видљива?

03

Аутоматизација предлаже или ограничава одговор када је последица грешке велика.

Питање: који доказ остаје после исхода?

ПИТАЊЕ ЗА АНАЛИЗУ

Који ризик контрола ублажава, који доказ чува и који сигнал показује да је престала да ради?

Доказ и учење

мери и побољшава

01

Корелациони идентификатор повезује намеру, обраду и исход једне радње.

Питање: који улаз покреће ову одлуку?

02

Правила корелације морају бити објашњива, посебно када утичу на приоритет упозорења.

Питање: која граница мора бити видљива?

03

Аутоматизација предлаже или ограничава одговор када је последица грешке велика.

Питање: који доказ остаје после исхода?

ПИТАЊЕ ЗА АНАЛИЗУ

Који ризик контрола ублажава, који доказ чува и који сигнал показује да је престала да ради?

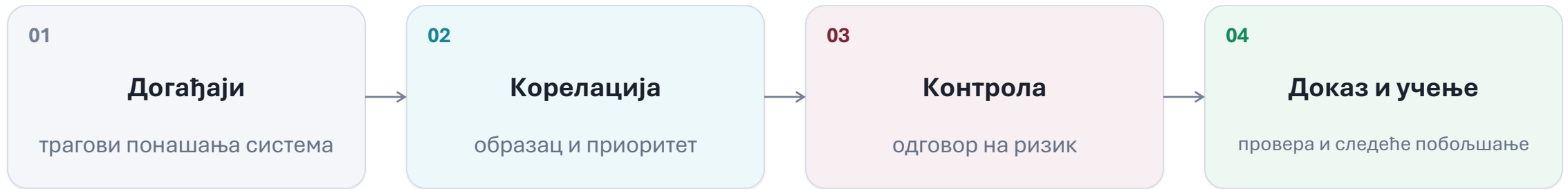
Доказ, покривеност и ефективност

Поређење приказује функцију сваког елемента и ограничење његове самосталне примене.

Питање	Слаб одговор	Поуздан одговор
Да ли контрола постоји?	Класа или подешавање је присутно.	Контрола има власника, активну конфигурацију и сврху.
Да ли ради?	Једном је ручно проверена.	Постоји поновљив тест или актуелан оперативни доказ.
Шта покрива?	Претпоставља се да важи свуда.	Познати су сценарио, граница и изузеци.
Како знамо да је ослабила?	Проблем се види тек после инцидента.	Метрика, alert или редован преглед откривају одступање.

Модел континуираног унапређивања безбедности

Безбедност напредује кроз повратну спрегу. доказ мења разумевање ризика, а то мења контролу.



ЕЛЕМЕНТИ АНАЛИЗЕ

Анализа сваког корака обухвата покретача, место одлуке и траг који остаје после исхода.

Безбедносна повратна спрега

Процес приказује улазе, место одлуке и доказ који остаје после исхода.

КОНТЕКСТ

Безбедносна повратна спрега

Зрео систем не завршава безбедност имплементацијом контроле. Догађаји и тестови стварају доказ, доказ мења процену ризика, а процена ризика води ка бољој политици или другачијој контроли. Тако се избегава лажни осећај да је једном завршени посао заувек довољан.

01

Догађај или тест открива образац који захтева пажњу.

02

Корелација повезује образац са имовином, актером и контролом.

03

Тим проверава да ли постојећа контрола покрива стварни сценарио.

04

Нова одлука ствара ажурирану политику, тест или оперативну процедуру.

Контрола има смисао тек уз доказ

Наведена правила остају видљива у имплементацији, тестовима и ревизији.

01

Корелација повезује догађаје по времену, актеру и ресурсу, уз садржај појединачних порука лога.

Јасно правило

02

Одговор са већим последицама захтева људску одлуку и јасан траг одобрења.

Проверљива примена

03

Постинцидентни преглед испитује системске и процесне узроке догађаја.

Видљив доказ

Примена у развоју

Тим примењује тему кроз серверске провере, тестове и ревизионе записе током развоја.

РАЗВОЈНИ КОНТЕКСТ

Примена принципа у коду

Добра безбедносна анализа показује узрочну везу: коју имовину штитимо, који сценарио разматрамо, која контрола делује и како знамо да њено понашање још увек одговара намери. Кратак, јасан доказ вреди више од дуге листе функционалности.

01

Дефинисана одлука и њена граница.

02

Серверска имплементација провере.

03

Позитиван и негативан доказ.

Случај: контрола постоји, али нема свеж доказ

Случај повезује опште правило са конкретним контекстом, серверском провером и очекиваним исходом.

СЦЕНАРИО

Пример: контрола постоји, али нема свеж доказ

Систем има правило које ограничава приступ осетљивом ресурсу. Правило је било успешно тестирано пре неколико месеци, али се у међувремену променио модел улога и додат је нови улаз у систем. Без новог доказа тим зна да контрола постоји, али не зна да ли још покрива стварни ризик. Ефективност зато укључује свежину, опсег и резултат провере.

01

Корелација повезује низ догађаја у једну причу о понашању система.

02

Мера ефективности прати да ли контрола има власника, доказ и покривеност релевантног сценарија.

03

Аутоматизован одговор може убрзати реакцију, али радња са великом последицом задржава људску потврду и ревизиони траг.

Корелација гради причу, не закључак из једног записа

Корелација повезује догађаје по времену, актеру, ресурсу и идентификатору тока.

```
1 public Finding Correlate(IEnumerable<Event> events)
2 {
3     var story = events
4         .Where(e => e.CorrelationId != null)
5         .GroupBy(e => e.CorrelationId)
6         .Select(group => timeline.Build(group));
7     return detector.FindRiskPattern(story)
8         ?? Finding.None("insufficient_context");
9 }
```

ТУМАЧЕЊЕ

Време, актер, ресурс и correlation ID повезују догађаје у образац који може да се објасни.

БЕЗБЕДНОСНА ГРАНИЦА

Одбијање је експлицитан исход са разлогом који се може тестирати и објаснити.

Стар доказ не сме да изгледа као актуелна сигурност

Тест показује да застарео доказ не може подржати процену ефективности контроле.

```
1 [Fact]
2 public void Control_without_fresh_evidence_is_not_effective()
3 {
4     var control = Control.Tested(monthsAgo: 8);
5
6     var score = effectiveness.Evaluate(control, changedFlow: true);
7
8     score.Status.Should().Be("unknown");
9     score.Reason.Should().Be("stale_evidence");
10 }
```

ДОКАЗ

Промена тока или истек рока враћа оцену на непознато док се контрола поново не провери.

ОЧЕКИВАНИ ИСХОД

Тест мења једну чињеницу и очекује јасан, стабилан разлог одбијања.

Садржај безбедносног записа

Запис садржи контекст потребан за реконструкцију одлуке, без тајни и непотребних личних података.

```
1 {  
2   "control": "object-authorization",  
3   "risk": "cross-tenant-access",  
4   "lastEvidence": "2026-09-20",  
5   "coveredScenario": "foreign-record-denied",  
6   "status": "effective",  
7   "nextReview": "2026-10-20"  
8 }
```

ДОВОЉНО

Актер, радња, циљ, исход и разлог

Временска ознака и correlation ID повезују траг са остатком тока.

НЕ ПРИПАДА У ДОКАЗ

Лозинка, token, тајна и сувишан садржај

Траг не сме да постане нови извор цурења или збирка непотребних података.

Честе грешке у имплементацији

Грешке настају када контекст, место одлуке или доказ остану нејасни.

01

**Закључивање из једног
догађаја без ширег контекста.**

Нема јасног власника одлуке.

02

**Аутоматска акција са великом
последicom без заштитне
провере.**

Не постоји негативан сценарио.

03

**Оцена контроле само по томе
да ли је имплементирана.**

Доказ не показује стварни исход.

Процена ефективности контроле

Процена користи актуелан доказ, покривеност релевантних сценарија и позната ограничења.

ОБРАЗЛОЖЕЊЕ

ЕФЕКТИВНОСТ КОНТРОЛЕ

Контрола може бити имплементирана, али погрешно подешена, заобиђена новим током или застарела после промене система. Зато се њена ефективност процењује кроз доказ: последњи успешан тест, покривени сценарио, власника и способност да се проблем примети ако контрола закаже.

01

Доказ се освежава када се промени релевантан ток, улога или граница поверења.

02

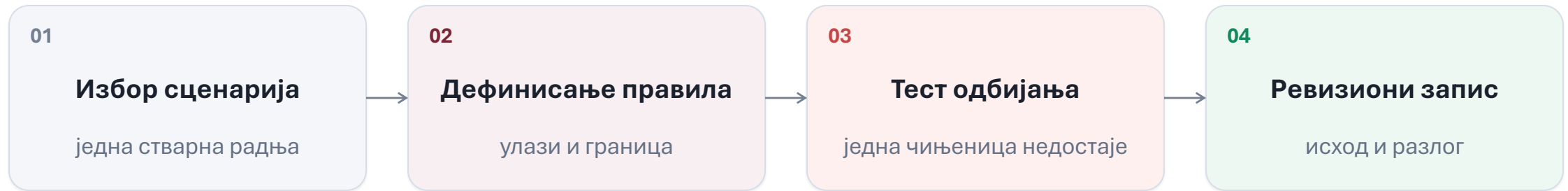
Мера ефективности јасно приказује области за које нема довољно доказа.

03

Квалитетна анализа повезује ризик, контролу, тест и преостало ограничење у једну јасну причу.

Примена на пројекат

Анализа једног сценарија обухвата одлуку, имплементацију, тест одбијања и доказ.

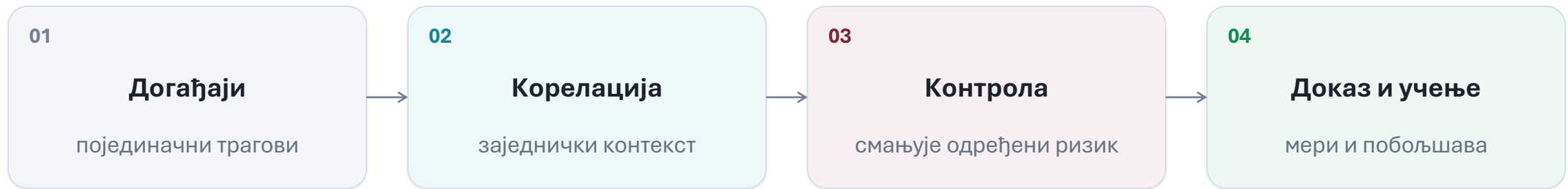


ПРИМЕНА НА ПРОЈЕКАТ

Пројектна примена теме „Корелација догађаја, ефективност контрола и учење“ обухвата једну серверску одлуку, тест одбијања и доказ који други члан тима може да понови.

Провера разумевања

Разумевање теме подразумева објашњење одлуке и доказа независно од конкретног технолошког оквира.



ПИТАЊЕ ЗА ПРОВЕРУ

Који ризик контрола ублажава, који доказ чува и који сигнал показује да је престала да ради?

Пројектна примена: применити исти модел на једну реалну границу у сопственом пројекту.